

2026학년도 웹 개발 프로그래밍

“SecureLens” 제안서

학번 2111 이름 유서희

2026. 04. 07



대덕소프트웨어마이스터고등학교

1. 서비스 개요 ※ (가.~다. : 2페이지 이상 작성)

가. 배경과 개발목표

※ 제안자가 느끼는 절실한 문제점이 포함되어야 함(글자 크기, 11p)

현재 교내 환경은 다양한 서비스 개발이 활발하게 이루어지고 있으나, 보안적인 부분에 있어 체계적으로 바줄 사람이나 과정이 많이 부족하다. 이는 다음과 같은 문제점을 일으킨다.

첫째, 보안에 대한 인식과 문화가 부족하다. 프로젝트를 할 때 보안 전공 학생들에게 검토를 요청하거나 피드백을 받는 문화가 없다. 이러다 보니 코드에 잠재적인 취약점이 방치될 가능성이 있다. 개발자들은 일단 기능 만드는 데에만 집중하다 보니, 보안은 자꾸 뒤로 밀리게 되고, 결국 서비스 안정성과 신뢰도를 떨어뜨리는 원인이 된다.

둘째, 실사용 서비스의 위험성이 존재한다. 학교에서 이미 쓰고 있는 서비스들이 제대로 된 보안 점검 없이 배포되다 보니, 언제든 사용자 데이터 유출 혹은 서비스 중단과 같은 사고가 생길 가능성이 있다.

셋째, 기존 보안 도구의 진입 장벽이 높다. 전문가들이 쓰는 정적 분석 도구(SAST)를 학생들이 쓰기에는 기술적으로 부족하고, 사용법도 너무 어렵다는 문제가 있다. 이런 툴들은 코드를 빠르게 훑어서 취약점을 찾아주긴 하지만, 코드 전체의 흐름이나 중요한 로직을 제대로 이해하지 못할 때가 많다. 이로 인해 실제 취약점이 아님에도 불구하고 경고를 발생시키는 오탐률이 높게 나타나, 개발자가 불필요한 시간 낭비를 하게 만든다. 이런 오탐 때문에 진짜 중요한 취약점을 놓치게 되기도 한다.

넷째, 보안 전문가와 개발자 사이에 지식 격차가 크다. 기존 보안 도구가 탐지한 취약점 보고서는 종종 전문적인 보안 용어와 기술적 설명으로 가득 차 있어, 보안 지식이 부족한 일반 개발자나 비보안 직군이 정확히 이해하는 데에 어려움을 겪는다. 결국 취약점을 고치는 게 늦어지거나, 잘못 고치게 되어 새로운 보안 문제를 생성할 수도 있다.

다섯째, 취약점 수정 가이드가 없을 뿐만 아니라, 있어도 비효율적인 부분이 크다. 대부분의 툴들은 취약점의 존재를 알려주지만 할 뿐, 이게 왜 문제인지, 어떻게 고쳐야 하는지 친절하게 알려주지 않는다. 특히 내 코드에 딱 맞는 수정 예시가 없어서, 결국 개발자들이 직접 구글링해야 하며 해결 방법을 찾아야 해서 부담이 크다.

위와 같은 문제를 해결하고자 SecureLens를 구상하게 되었다. 본 프로젝트는 누구나 자신의 소스 코드를 입력하기만 하면 AI가 취약점을 분석하고 해결책을 제시해 주는 '사용자 친화적 AI 기반 코드 취약점 분석 플랫폼' 구축을 목표로 한다.

이를 위한 구체적인 개발 목표는 다음과 같다.

•정밀 분석 시스템 구현: 단순히 정해진 규칙에 의해 취약점을 찾는 기존 방식(Rule-Based)에 LLM(Large Language Model)을 결합하여, 단순한 패턴 매칭을 넘어 코드의 전체적인 맥락과 데이터 흐름까지 파악하는 정밀한 분석을 제공한다. 이를 통해 기존 정적 분석의 한계를 극복하고, 더욱 깊이 있는 보안 진단을 가능하게 한다.

•오탐 최소화 및 정확도 향상: AI가 분석 결과를 다시 한 번 검토하여 실제 위협이 되는 취약점만 골라냄으로써 분석 결과에 대한 신뢰도를 높인다. 불필요한 오탐으로 인한 개발자의 시간 낭비를 줄이고, 실제 보안 위협에 집중할 수 있도록 지원한다.

•보안 가이드 제공: 탐지된 취약점에 대해 AI가 보안 비전공자도 이해하기 쉬운 설명과 안전한 수정 코드 예시를 제공하여, 개발 과정에서 자연스럽게 보안 지식을 얻을 수 있도록 돕는다. 이는 개발자 스스로 시큐어 코딩 역량을 강화하는 교육적 효과를 가져올 것이다.

•통합 관리 대시보드 구축: 분석 이력과 취약점 통계를 시각화하여 제공함으로써 프

로젝트의 전반적인 보안 수준을 한눈에 관리할 수 있도록 한다. 사용자는 직관적인 대시보드를 통해 자신의 코드 보안 상태를 쉽게 파악하고, 필요한 조치를 취할 수 있다.

나. 서비스 개념

※ (서비스의 개요를 6하 원칙에 따라 핵심 단어 중심으로 간략히 작성 : 고객, 제공 가치, (프론트엔드단)기술 구현, 제공 방법 등)

SecureLens는 교내 학생 개발자를 주 대상으로 한다 더 나아가서는 안전한 코드를 만들고 싶은 모든 개발자들이 쓸 수 있다. 프로젝트를 개발하는 중간이나, 서비스를 사람들에게 공개하기 전에 내 코드에 보안 문제가 없는지 스스로 확인하고 싶을 때 사용하면 된다. 별도의 설치 없이 웹 브라우저를 통해 접속하여 사용할 수 있다.

SecureLens는 소스 코드 속의 보안 약점을 찾아내고, AI가 생성한 쉬운 설명과 안전한 수정 코드를 제공하여 보안 사고를 예방하는 것을 핵심 가치로 한다. 이는 보안 전문가의 도움 없이도 개발자 스스로 코드의 안전성을 확보하고, 분석 과정에서 자연스럽게 보안 지식을 학습할 수 있도록 돕기 위함이다.

구현 방식: React.js를 사용해서 코드를 넣는 창과 분석 결과를 그래프로 보여주는 깔끔한 대시보드를 만든다. 사용자가 코드를 넣으면, 1차로 규칙 기반 분석(Rule-Based)을 하고, 2차로 AI(GPT)가 깊게 분석해서 정확한 결과를 리포트처럼 보여준다.

다. 주요 타겟 고객

※ 이 서비스는 누가 쓸 것인가? 사용자에게 어떤 가치(혜택)를 줄 수 있는가?

SecureLens가 주로 타겟으로 하는 고객은 다음과 같다.

1. 주니어 개발자 및 학생 개발자: 아직 보안 경험이 많지 않아서 코드를 짤 때 어떻게 취약점인지 잘 모르고, 기존 보안 툴의 어려운 보고서를 해석하기 힘들어하는 개발자들이다. SecureLens는 이 친구들에게 쉽고 명확한 취약점 설명과 바로 고칠 수 있는 가이드를 줘서, 자연스럽게 시큐어 코딩 습관을 기르고 보안 실력을 키울 수 있도록 도와준다.
2. 스타트업 및 중소기업 개발팀: 회사에 보안만 전문으로 하는 사람이 없거나, 비싼 상용 보안 솔루션을 쓰기 부담스러운 개발팀이다. SecureLens는 저렴한 비용으로 AI 기반의 수준 높은 보안 분석 기능을 제공해서, 적은 인원으로도 개발 과정의 보안 수준을 끌어올릴 수 있게 도와준다.
3. 오픈소스 프로젝트 기여자: 여러 개발자들이 함께 만드는 오픈소스 프로젝트에서 코드의 보안 품질을 지키고, 다른 사람들이 올린 코드의 취약점을 쉽게 찾아서 고칠 수 있도록 돕는다.

사용자에게 제공하는 가치(혜택)

- 시간과 비용 절약: 까짜 경고를 줄여주고, 자동으로 수정 코드를 만들어줘서 쓸데없는 보안 검토 시간을 아낄 수 있다. 취약점을 고치는 데 들어가는 개발 시간과 노력을 아낄 수 있다.
- 보안 실력 향상: AI가 친절하게 설명해주고, 수정 예시까지 보여줘서 개발자 스스로 취약점의 원리를 이해하고 안전한 코드를 짜는 방법을 배울 수 있다.
- 소프트웨어 품질 향상: 개발 초반부터 보안 구멍을 효과적으로 막아서, 최종으로 만들어진 서비스의 보안과 신뢰도를 높일 수 있다.
- 개발 생산성 증가: 보안 문제 때문에 개발이 막히는 일을 줄여주고, 개발자가 진짜 중요한 기능 개발에 더 집중할 수 있게 해준다.

라. 웹 개발 주요 서비스 내용

※ (최대한 구체적으로 기술, 2페이지 이상 작성, 프론트단 기준으로 작성)

1) 주요 서비스 기능

① 코드 제출 및 분석 시작: 모든 분석의 첫걸음
사용자가 SecureLens와 처음 만나는 화면이다. 이 단계의 목표는 어떤 형태의 코드든 쉽고 빠르게 분석 큐에 등록할 수 있게 하는 것이다. 화면은 크게 세 가지 코드 제출 방식으로 나뉜다.

- 코드 에디터에 직접 붙여넣기: 화면 중앙에는 코드 하이라이팅 기능이 적용된 텍스트 에디터가 있다. Monaco Editor를 사용하여 개발자들이 익숙한 환경을 만들어준다. 사용자는 분석하고 싶은 Python 코드를 여기에 바로 복사해서 붙여넣을 수 있다. 에디터는 줄 번호를 표시하고, 기본적인 문법 오류를 시각적으로 알려주어 사용자가 코드를 올리기 전에 간단히 확인할 수 있게 돕는다. 코드를 입력하는 동안 실시간으로 구문 강조가 되어 가독성이 매우 뛰어나다.
- 파일 업로드: 로컬 컴퓨터에 저장된 .py 파일을 직접 올릴 수 있다. 사용자는 '파일 선택' 버튼을 누르거나, 지정된 영역에 파일을 드래그 앤 드롭하여 업로드할 수 있다. 여러 파일을 동시에 올리는 것도 가능해서, 여러 개의 스크립트 파일을 한 번에 분석할 때 아주 편리하다. 업로드된 파일의 이름과 크기가 목록으로 표시되어 사용자가 어떤 파일을 올렸는지 쉽게 확인할 수 있다.
- 코드 올리고 '분석 시작' 버튼: 버튼을 누르면, 버튼은 비활성화되고 로딩 애니메이션이 표시된다. 프론트엔드는 백엔드 API로 코드 데이터를 전송하고, 백엔드는 2단계 분석 프로세스를 시작한다. 1차로 빠른 정적 분석을 수행하고, 2차로 1차 분석 결과를 바탕으로 OpenAI를 호출하여 코드의 맥락을 깊이 있게 파고드는 심층 분석을 진행한다. 이 모든 과정은 사용자에게 '1단계: 정적 분석 중...', '2단계: AI 심층 분석 중...', '3단계: 결과 생성 중...'과 같은 실시간 상태 메시지로 투명하게 공유된다. 분석이 길어질 경우 예상 완료 시간도 함께 보여주어 사용자가 답답함을 느끼지 않게 한다.

② 분석 결과 요약 대시보드: 내 코드의 건강검진 결과표

분석이 완료되면 사용자는 결과 요약 대시보드로 자동 이동한다. 이 화면은 복잡한 분석 결과를 한눈에 파악할 수 있는 '건강검진 결과표'와 같다. 대시보드는 다음과 같은 시각적 요소들로 구성된다.

- 종합 보안 점수: 분석된 코드의 전반적인 보안 수준을 100점 만점의 점수로 환산하여 보여준다. 이 점수는 발견된 취약점의 개수와 심각도(Critical은 감점 폭이 크고, Low는 작음)를 종합하여 계산되며, 사용자는 이 점수를 통해 자신의 코드 상태를 직관적으로 인지할 수 있다. 점수가 낮으면 위험하다는 것을 바로 알 수 있다.
 - 심각도별 취약점 분포: 발견된 취약점들을 'Critical', 'High', 'Medium', 'Low' 네 단계의 심각도로 나누어, 각 등급에 해당하는 취약점이 몇 개인지 보여준다. 이 정보는 Chart.js나 Recharts 같은 라이브러리를 활용한 도넛 차트나 막대그래프로 시각화되어 어떤 종류의 위험이 가장 많은지 쉽게 파악할 수 있게 한다. 차트의 각 부분을 클릭하면 해당 심각도의 취약점 목록만 필터링해서 볼 수 있다.
 - 취약점 유형별 통계: SQL Injection, XSS, Command Injection 등 OWASP Top 10을 기준으로 어떤 유형의 취약점이 발견되었는지 목록과 개수를 보여준다. 이를 통해 사용자는 자신의 코드가 어떤 종류의 공격에 취약한지 경향성을 파악할 수 있다. 예를 들어, 'SQL Injection'이 가장 많다면 데이터베이스 관련 보안에 더 신경 써야 한다는 것을 알 수 있다.
 - 취약점 목록 테이블: 발견된 모든 취약점은 테이블 형태로 정리된다. 각 행은 하나의 취약점을 나타내며, 심각도, 취약점 유형, 발생 파일, 코드 라인, '간략 설명' 정보를 포함한다. 사용자는 이 테이블에서 특정 취약점 행을 클릭하여 상세 정보 페이지로 이동할 수 있다. 테이블은 정렬 및 검색 기능을 제공하여 사용자가 원하는 취약점을 쉽게 찾을 수 있게 한다.
- 이 모든 정보는 React와 Chart.js 같은 라이브러리를 활용하여 동적이고 인터랙티브하게 구현된다. 사용자가 차트의 특정 부분에 마우스를 올리면 추가 정보가 팝업으로 나타나는 등, 데이터를 탐색하는 재미를 더한다.

③ 취약점 상세 정보와 AI 과외 선생님: 1:1 맞춤형 보안 가이드

이 화면은 SecureLens의 핵심 가치가 가장 잘 드러나는 부분으로, 단순한 결과 보고를 넘어 사용자에게 '1:1 보안 과외 선생님'이 되어준다. 사용자가 대시보드에서 특정 취약점을 클릭하면, 해당 취약점에 대한 모든 정보가 여기에 집약되어 나타난다.

- 코드 뷰어: 화면 상단에는 취약점이 발견된 코드 부분이 하이라이팅된 상태로 표시

된다. 어느 파일, 몇 번째 줄에 문제가 있는지 시각적으로 명확하게 보여주어 사용자가 문제의 위치를 즉시 파악할 수 있게 한다. 주변 코드 맥락도 함께 보여줘서, 취약점이 발생한 원인을 더 쉽게 이해할 수 있게 돕는다.

•AI의 상세 분석 리포트: 코드 뷰어 아래에는 AI가 생성한 상세 분석 리포트가 탭 형태로 제공된다. 각 탭은 다음과 같은 내용을 담고 있다.

•한 줄 요약: 사용자 입력을 그대로 SQL 쿼리에 사용해서 해커가 데이터베이스를 조작할 수 있어요. 비밀번호를 코드에 직접 써놔서 누구나 볼 수 있어요. 와 같이 취약점의 핵심을 한 문장으로 요약하여 보여준다. 바쁜 개발자도 빠르게 핵심을 파악할 수 있게 한다.

•상세 설명: 이 취약점이 무엇인지, 왜 위험한지, 어떤 원리로 공격이 이루어지는지를 비유나 쉬운 예시를 들어 설명한다. 예를 들어, SQL Injection은 “마치 식당에서 주문할 때 메뉴판에 없는 이상한 말을 해서 주방을 혼란스럽게 만드는 것과 같아요.” 처럼 설명해서 보안을 처음 접하는 학생 개발자의 눈높이에 맞춰 친절하게 서술한다. 전문 용어는 최소화하고, 꼭 필요한 경우 쉽게 풀어서 설명한다.

•내 코드의 문제점: AI가 사용자의 코드 맥락을 분석하여, user_input 변수에 들어온 값을 아무런 검증 없이 바로 db.execute() 함수에 넣고 있어서 위험해요. 해커가 여기에 악성 SQL 코드를 넣으면 데이터베이스를 마음대로 조작할 수 있어요. 와 같이 정확히 어떤 부분이 문제의 원인인지 콕 집어 설명한다. 단순히 취약점 유형만 알려주는 게 아니라, 내 코드에 맞춰서 설명해주는 것이 핵심이다.

•추천 수정 코드: 현재 코드와 안전하게 수정된 코드를 나란히 비교(Side-by-Side Diff)하여 보여준다. 삭제된 부분은 붉은색, 추가된 부분은 녹색으로 표시하여 변경 사항을 명확하게 인지할 수 있게 한다. 수정된 코드 아래에는 “?를 사용하는 파라미터화된 쿼리 방식으로 바꾸면, 입력값이 코드가 아닌 데이터로만 취급되어서 SQL 인젝션 공격을 막을 수 있어요. 이렇게 하면 해커가 어떤 값을 넣어도 안전하게 처리된답니다.” 와 같이 왜 이렇게 고쳐야 하는지에 대한 설명도 덧붙인다. 개발자는 이 코드를 바로 복사해서 자기 프로젝트에 적용할 수 있다.

•더 알아보기: 해당 취약점에 대해 더 깊이 공부하고 싶은 사용자를 위해 OWASP Top 10 페이지나 신뢰할 수 있는 기술 블로그, 보안 커뮤니티 링크를 제공한다. 이는 사용자가 스스로 보안 지식을 확장할 수 있는 기회를 제공한다. •오람 신고 기능: 만약 AI의 분석이 틀렸다고 생각되면, 사용자는 ‘이건 오람인 것 같아요’ 버튼을 눌러 피드백을 보낼 수 있다. 이 피드백은 백엔드로 전송되어 AI 모델을 지속적으로 학습시키고 개선하는 데 사용된다. 사용자의 참여가 SecureLens를 더 독특하게 만드는 것이다.

④ 분석 기록 관리 및 리포트 다운로드

사용자가 SecureLens를 꾸준히 사용하면서 자신의 보안 실력이 향상되는 과정을 추적하고 관리할 수 있는 기능이다. 마치 나의 보안 성장 일기를 보는 것과 같다.

•분석 히스토리: ‘마이페이지’에 들어가면 과거에 수행했던 모든 분석 기록이 최신순으로 정렬된 목록으로 나타난다. 각 기록에는 분석 날짜, 분석한 파일명 또는 GitHub 저장소 이름, 종합 보안 점수, 발견된 취약점 개수, 심각도별 분포 요약 등이 표시되어, 시간의 흐름에 따라 내 코드의 보안 수준이 어떻게 변했는지 쉽게 확인할 수 있다. 각 기록을 클릭하면 해당 시점의 분석 결과 대시보드로 다시 돌아갈 수 있다. 검색창과 필터링 기능을 제공하여 특정 기간이나 특정 파일의 분석 기록만 찾아볼 수도 있다.

•리포트 다운로드: 모든 분석 결과는 깔끔하게 정리된 PDF 또는 마크다운 형식의 리포트로 다운로드할 수 있다. 이 리포트에는 종합 분석 결과, 심각도별 통계 차트, 전체 취약점 목록, 그리고 각 취약점에 대한 AI의 상세 설명과 수정 코드 가이드가 모두 포함된다. 이 리포트는 프로젝트 발표 자료로 활용하거나, 팀원들과 보안 이슈를 공유하고, 심지어는 취업 포트폴리오에 첨부하는 등 매우 유용하게 사용할 수 있다. 리포트에는 SecureLens 로고와 분석 날짜가 명확히 표시되어 신뢰도를 높인다.

2) 서비스 시나리오

<예시>

[시나리오 3]

시놉시스	홍길동 씨는 채팅에서 필요한 정보를 얻기 위해 기억을 되살리며 그 채팅이 있던 곳으로 직접 스크롤해서 찾았다.
니즈	채팅 내용에서 검색을 해 찾을 수 있으면 좋겠다.
불편사항	검색 기능이 없어 지난 채팅의 내용을 기억할 수 없고, 직접 시간을 들여 대화 내역을 찾아야 한다.
대안마련	채팅의 내역을 쉽게 확인할 수 있게 검색 기능을 지원한다.
기능	채팅방에서 검색을 할 수 있다. 또한 채팅방에서 주고받은 파일과 이미지를 모아 볼 수 있다.

[시나리오 1] - 신입 개발자의 코드 보안 검토

•시놉시스: 신입 개발자 김보안 씨는 최근 자기가 만든 웹 서비스의 Python 코드에 혹시 보안 구멍이 있을까 봐 걱정이다. 보안 지식이 많지 않아서 어디를 어떻게 봐야 할지 막막하다.

•니즈: 내가 짠 코드의 보안 취약점을 쉽고 빠르게 확인하고, 찾은 취약점을 어떻게 고쳐야 할지 구체적인 방법을 알고 싶다.

•불편사항: 기존 보안 툴은 결과 보고서가 너무 어렵고 가짜 경고가 많아서 믿기 힘들다. 또, 취약점을 찾아도 어떻게 고칠지는 결국 내가 알아서 찾아봐야 해서 너무 힘들다.

•대안마련: SecureLens에 코드를 돌려보고, AI가 알려주는 친절한 설명과 수정 코드를 받아서 바로 고칠 수 있다.

•기능: 김보안 씨는 SecureLens 웹사이트에 접속한다. 메인 화면의 코드 에디터에 자기가 만든 Python 코드를 복사해서 붙여넣는다. Monaco Editor의 구분 칸조 덕분에 코드가 보기 좋게 표시된다. ‘분석 시작’ 버튼을 누르자, 화면 하단에 ‘1단계: 정적 분석 중...’이라는 메시지와 함께 진행 바가 나타난다. 잠시 후 ‘2단계: AI 심층 분석 중...’으로 바뀌고, 몇 분 뒤 분석이 완료되었다는 알림과 함께 결과 대시보드로 자동 이동한다. 대시보드에는 종합 보안 점수 75점과 함께 심각도별 취약점 분포가 파이프 차트로 예쁘게 그려져 있다. ‘High’ 등급의 ‘SQL Injection’ 취약점이 눈에 띄어 클릭한다. 상세 페이지로 이동하자, 왼쪽에는 취약점이 발생한 코드 부분이 하이라이팅되어 있고, 오른쪽에는 AI 과의 선생님이 “사용자 입력을 그대로 SQL 쿼리에 사용해서 해커가 데이터베이스를 조작할 수 있어요.” 라고 한 줄 요약과 함께 친절하게 설명해준다. ‘추천 수정 코드’ 탭을 누르니, 안전하게 파라미터화된 쿼리로 바뀐 코드가 예시와 원래 코드와 비교되어 나타난다. 김보안 씨는 이 코드를 복사해서 자기 프로젝트에 바로 적용하고 보안 문제를 해결한다. 이제 김보안 씨는 SecureLens 덕분에 보안에 대한 자신감이 생겼다.

[시나리오 2] - 스타트업 개발팀의 정기 보안 점검

•시놉시스: 스타트업 개발팀 리더인 박팀장님은 매주 서비스에 새로운 기능이 추가될 때마다 보안 상태를 점검해야 한다. 하지만 팀에 보안 전문가가 없어서 비싼 돈 주고 외부 컨설팅을 받거나, 개발자들이 직접 코드를 하나하나 힘들게 검토하고 있다.

•니즈: 비싸지 않으면서도 믿을 만한 자동 보안 점검 툴을 써서, 서비스의 보안 문제를 꾸준히 관리하고 싶다.

•불편사항: 비싼 상용 툴은 돈이 부담되고, 공짜 툴은 가짜 경고가 너무 많아서 결과를 검토하는 데 시간이 더 걸린다. 매번 사람이 직접 코드를 보는 건 너무 비효율적이다.

•대안마련: SecureLens를 써서 정기적으로 코드 전체의 보안을 검사하고, AI가 한번 걸러준 정확한 결과와 수정 가이드를 받아서 효율적으로 보안을 관리할 수 있다.

•기능: 박팀장님은 SecureLens에 팀의 GitHub 코드 저장소를 OAuth 인증을 통해 안전하게 연결한다. 매주 금요일 오후 5시에 main 브랜치의 코드를 자동으로 분석하게 설정하고, 분석이 끝나면 팀원들에게 이메일로 알림을 보내도록 설정한다. 금요일 퇴근 전, 박팀장님은 SecureLens 대시보드에 접속하여 최신 분석 결과를 확인한다. 대시보드에는 지난주보다 종합 보안 점수가 5점 올랐다는 메시지와 함께, AI가 가짜 경고를 걸러낸 진짜 취약점 목록이 깔끔하게 정리되어 있다. ‘High’ 등급의 ‘Cross-Site Scripting (XSS)’ 취약점이 새로 발견되어 클러킹한다. AI가 이 취약점이 왜 위험한지, 어떤 공격에 사용될 수 있는지 상세히 설명해주고, HTML 이스케이프 처리를 하는 수정 코드를 제안한다. 박팀장님은 이 수정 코드를 팀원들에게 바로 공유하고, 다음 주 스프린트 백로그에 해당 취약점 수정을 최우선 과제로 등록한다. 또

한, 이번 주 분석 결과를 PDF 리포트로 다운받아 주간 회의 자료로 활용한다. SecureLens 덕분에 박팀장님은 팀의 보안 수준을 효율적으로 관리하고, 개발팀은 기능 개발에 더 집중할 수 있게 되었다.

2. 서비스 경쟁력/차별화 ※ (2페이지 이상 작성)

가. 경쟁(유사) 서비스 현황

※ (유사한 서비스 현황, 기존 시장 규모 및 확장 가능성, 프론트단 기준으로 작성)

ex) 1. 경쟁 서비스 이름
가. 장점
1) ...

나. 단점
1) ...

2. 경쟁 서비스 이름
...

1. Bandit (Python Security Linter)

•어떤 툴인가?: Python 코드를 위한 오픈소스 보안 런터이다. 코드를 쓱 훑어보면서 미리 정해진 규칙에 따라 보안 취약점을 찾아준다. 설치도 쉽고, 명령 한 줄로 바로 쓸 수 있어서 Python 개발자들이 많이 사용한다.

•장점: Python 코드에 특화되어 있어서 기본적인 취약점(예: 하드코딩된 비밀번호, SQL 인젝션 가능성 등)을 빠르게 찾아내는 데 효과적이다. 공짜라서 돈 걱정 없이 쓸 수 있고, CLI(명령어 창)에서 쉽게 돌릴 수 있다는 점이 매력적이다.

•단점: 가장 큰 문제는 가짜 경고(오탐, False Positive)가 너무 많다는 점이다. 코드의 전체적인 흐름이나 개발자의 의도를 파악하지 못하고, 단순히 패턴 매칭으로만 취약점을 찾기 때문에 실제로는 문제가 없는데도 경고를 띄우는 경우가 허다하다. 또, 취약점 설명이 너무 기술적이고 딱딱해서 보안을 잘 모르는 개발자는 이해하기 어렵다. 수정 코드도 직접 알려주지 않아서, 개발자가 알아서 해결 방법을 찾아야 하는 부담이 크다. 결국, 개발자들이 오탐을 걸러내고 해결책을 찾는 데 많은 시간을 낭비하게 만든다.

2. SonarQube (Code Quality and Security)

•어떤 툴인가?: 코드 품질과 보안을 종합적으로 관리해주는 플랫폼이다. 다양한 프로그래밍 언어를 지원하고, 개발 과정에 통합해서 지속적으로 코드 상태를 모니터링할 수 있게 해준다. 웹 대시보드를 통해 분석 결과를 시각적으로 보여주는 것이 특징이다.

•장점: 여러 언어를 한 번에 관리할 수 있고, 코드 품질 규칙까지 함께 점검해줘서 프로젝트의 전반적인 코드 상태를 높이는 데 좋다. 웹 대시보드가 잘 되어 있어서 분석 결과를 보기 편하고, 팀 단위로 협업하면서 코드 리뷰에 활용하기에도 유용하다.

•단점: 설치하고 설정하는 과정이 꽤 복잡하고, 서버를 따로 운영해야 해서 초기 진입 장벽이 높다. 제대로 된 기능을 쓰려면 비싼 유료 버전을 구매해야 하는 경우가 많다. 여전히 규칙 기반 분석의 한계로 오탐이 발생하며, AI처럼 코드의 맥락을 깊이 있게 이해하거나 자동 수정 코드를 제안하는 기능은 제공하지 않는다. 우리 같은 학생 개발자들이 개인 프로젝트에 적용하기에는 너무 거창하고 부담스러운 툴이다.

3. Snyk (Developer Security Platform)

•어떤 툴인가?: 코드뿐만 아니라 오픈소스 라이브러리, 컨테이너 이미지, IaC(Infrastructure as Code) 등 개발 생명주기 전반의 보안을 관리해주는 개발자 중심의 보안 플랫폼이다. 개발자가 쓰는 IDE(통합 개발 환경)에 바로 연동해서 쓸 수 있고, 일부 취약점은 자동으로 수정해주는 기능도 제공한다.

•장점: 개발자가 익숙한 환경에서 보안 점검을 할 수 있게 해줘서 편리하다. 오픈소스 라이브러리의 취약점까지 찾아주는 점은 매우 강력하다. 일부 취약점에 대해서는 자동 수정 PR(Pull Request)을 생성해줘서 개발자의 수고를 덜어주기도 한다.

•단점: 기본적으로 유료 서비스라서 비용 부담이 크다. AI가 코드의 복잡한 흐름을 깊게 분석하거나, 오탐을 정교하게 검토하는 기능은 아직 부족하다. 자동 수정 기능도 모든 취약점에 적용되는 것은 아니며, 때로는 개발자의 추가적인 검토가 필요하다. 또한, 제공되는 수정 가이드가 모든 상황에 딱 맞지 않아서, 결국 개발자가 직접 고민해야 하는 부분이 여전히 존재한다.

나. 경쟁(유사) 서비스 대비 차별화 요소

- * 고객이 느끼는 타 서비스 대비 차별화 요소, 프론트단 기능적인 측면에서 제시 (잘못된 예시)
 - 무료 서비스이다.(X)
 - 이 서비스는 앱(또는 웹)에서도 제공한다.(X)
 - 웹에서 어떠한 기능을 제공하므로 어떠한 부분에서 사용자가 더 편리한 사용을 할 수 있는지 구체적으로 작성

<예시>

2) 포트폴리스트만의 '터칭' 기능이 있다. 터칭은 흔히 sns에 쓰이는 '팔로우'와 '좋아요' 기능을 하나로 합친 것으로 볼 수 있다. behance에도 좋아요가 있지만 팔로우 기능은 없다. 사용자가 다른 사용자를 터칭할 경우 터칭하는 사용자는 '터쳐(toucher)'라고 불리며 터칭 당한 사용자의 포트폴리오에 수정이 있을 경우에는 알림을 통해 변경 사항이 존재한다는 것을 알 수 있다.

SecureLens는 기존 보안 툴들이 가진 아쉬운 점들을 보완하고, 특히 우리 학교 학생 개발자들처럼 보안 지식이 부족하거나 경험이 적은 개발자들이 쉽고 편하게 보안을 강화할 수 있도록 다음과 같은 확실한 차별점을 가진다. 이걸 단순히 기능 몇 개를 더 넣은 게 아니라, 개발자의 실제 고민을 해결해주는 데 집중한 결과이다.

1. AI가 가짜 경고(오탐)를 확 줄여주는 '심층 분석': SecureLens의 가장 강력한 차별점은 AI를 활용한 2단계 분석이다. 1차로 Bandit 같은 빠른 정적 분석 툴로 기본적인 취약점을 찾아낸 뒤, 2차로 AI(GPT-4o-mini)가 1차 분석 결과를 바탕으로 코드의 전체적인 흐름과 맥락을 깊이 있게 파고든다. 예를 들어, Bandit이 '사용자 입력이 SQL 쿼리에 들어간다'는 이유만으로 무조건 SQL Injection 경고를 띄웠다면, SecureLens의 AI는 해당 입력값이 DB에 전달되기 전에 적절한 검증이나 이스케이프 처리를 거치는지까지 확인한다. 만약 안전장치가 있다면, AI는 이것을 '안전한 코드'로 판단하고 최종 보고서에서 제외한다. 이 과정을 통해 개발자의 시간을 낭비하게 만드는 가짜 경고를 획기적으로 줄여주고, 개발자는 진짜 위험한 '진짜배기 취약점'에만 집중할 수 있다. 이는 개발자의 피로도를 낮추고, 보안 업무의 효율을 극대화하는 핵심적인 차별점이다.

2. 친절한 '1:1 AI 보안 과외 선생님': 다른 보안 툴들은 취약점을 찾아도 'SQL Injection'이나 'XSS'니 하는 어려운 용어만 던져주고, 어떻게 고쳐야 할지는 개발자 스스로 알아서 찾아보라고 한다. 보안을 잘 모르는 학생 개발자들에게는 이게 가장 큰 장벽이다. SecureLens는 이 문제를 해결하기 위해 AI를 '1:1 보안 과외 선생님'처럼 활용한다. AI는 발견된 취약점에 대해 다음과 같은 맞춤형 가이드를 제공한다.

- 쉬운 설명: 취약점이 무엇인지, 왜 위험한지, 어떤 원리로 공격이 이루어지는지를 비유나 쉬운 예시를 들어 설명한다. 예를 들어, SQL Injection은 '마치 식당에서 주, 문할 때 메뉴판에 없는 이상한 말을 해서 주방을 혼란스럽게 만드는 것과 같아요.' 처럼 설명해서 보안을 처음 접하는 학생 개발자의 눈높이에 맞춰 친절하게 서술한다. 전문 용어는 최소화하고, 꼭 필요한 경우 쉽게 풀어서 설명한다.

- 내 코드의 문제점: 단순히 취약점 유형만 알려주는 게 아니라, 사용자의 코드 맥락을 분석하여 'user_input 변수에 들어온 값을 아무런 검증 없이 바로 db.execute() 함수에 넣고 있어서 위험해요.' 와 같이 정확히 어떤 부분이 문제의 원인인지 콕 집어 설명한다. 이는 개발자가 자신의 코드에서 무엇을 고쳐야 할지 명확하게 이해하는 데 큰 도움을 준다.

- 추천 수정 코드: 현재 코드와 안전하게 수정된 코드를 나란히 비교(Side-by-Side Diff)하여 보여준다. 삭제된 부분은 붉은색, 추가된 부분은 녹색으로 표시하여 변경 사항을 명확하게 인지할 수 있게 한다. 수정된 코드 아래에는 '파라미터화된 쿼리 방식으로 바꾸면, 입력값이 코드가 아닌 데이터로만 취급되어서 SQL 인젝션 공격을 막을 수 있어요.' 와 같이 왜 이렇게 고쳐야 하는지에 대한 설명도 덧붙인다. 개발자는 이 코드를 바로 복사해서 자기 프로젝트에 적용할 수 있다. 이처럼 SecureLens는 개발자가 취약점을 '발견'하는 것을 넘어 '이해'하고 '해결'하는 전 과정을 지원하여, 개발자 스스로 보안 실력을 키울 수 있도록 돕는 교육적인 역할까지 수행한다.

3. 개발자 친화적인 사용자 경험(UX): "보안 점검이 이렇게 쉬운 수가!": 기존 보안 툴들은 설치부터 사용법까지 복잡하고 어렵다. 특히 CLI(명령어 창) 기반의 툴들은 비

전공자에게는 큰 장벽이다. SecureLens는 웹 기반 서비스로, 별도의 설치 없이 웹 브라우저만 있으면 언제 어디서든 접속해서 사용할 수 있다. 코드를 붙여넣거나 파일을 올리는 것도 마우스 클릭 몇 번이면 끝이다. 분석 결과는 종합 보안 점수, 심각도 별 차트, 유형별 통계 등 직관적인 대시보드로 한눈에 보여준다. 마치 내 코드의 '건강검진 결과표'를 보는 것처럼 말이다. 복잡한 보고서를 읽을 필요 없이, 중요한 정보만 쏙쏙 뽑아서 보여주기 때문에 보안을 잘 모르는 개발자도 쉽게 이해하고 활용할 수 있다. 또한, GitHub 연동 기능을 통해 코드 변경 시 자동으로 분석을 시작하고 결과를 알려주어, 개발 과정에 보안 점검을 자연스럽게 녹여낼 수 있다. 이는 개발자가 보안 점검을 귀찮은 일이 아니라, 개발 과정의 필수적이고 편리한 부분으로 인식하게 만든다.

4. 지속적인 학습과 발전: "사용자와 함께 똑똑해지는 AI": SecureLens의 AI는 단순히 정해진 규칙에 따라 동작하는 것이 아니다. 사용자들이 '이건 오탐인 것 같아요'라고 신고하거나, '이 수정 코드가 더 좋아요'라고 피드백을 주면, 이 데이터들을 바탕으로 AI 모델은 계속해서 학습하고 발전한다. 즉, 사용자들이 SecureLens를 많이 쓸수록 AI는 더 똑똑해지고, 오탐은 더 줄어들며, 수정 가이드는 더 정확하고 유용해지는 것이다. 이는 SecureLens가 정체되지 않고 끊임없이 진화하는 서비스임을 의미한다. 사용자의 참여가 서비스의 품질을 높이는 선순환 구조를 만들어, 시간이 지날수록 SecureLens는 다른 어떤 툴보다도 강력하고 신뢰할 수 있는 보안 분석 플랫폼이 될 것이다. 이는 단순히 기술적인 우위를 넘어, 사용자 커뮤니티와 함께 성장하는 지속 가능한 경쟁력이다.

3. 개발 계획 ※ (1페이지 이상 작성)

가. 웹 개발시 사용할 기술 스택

*리엑트는 반드시 들어가야 함.

React.js, Tailwind CSS, OpenAI API, SQLite, Git & Github

나. 리엑트로 만든 컴포넌트

*컴포넌트 3개 이상 작성하고 그 컴포넌트의 기능 설명

1. CodeInputForm 컴포넌트

•기능: 사용자가 분석할 코드를 붙여넣거나 파일을 올리는 화면이다. 텍스트 입력창, 파일 업로드 버튼, 분석 시작 버튼으로 구성된다. 사용자가 입력한 코드를 백엔드 API로 보내는 역할을 한다.

•특징: 사용자가 최대한 편하게 코드를 올릴 수 있게 만드는 데 집중한다. 코드 하이라이팅 라이브러리를 써서 입력된 코드를 보기 좋게 만들어준다.

2. VulnerabilityDashboard 컴포넌트

•기능: 분석 결과를 요약해서 보여주는 화면이다. 전체 취약점 개수, 심각도별 분포(파이 차트 등), 분석 시간 같은 정보를 보여준다. 각 항목을 누르면 상세 정보로 넘어가는 기능을 제공한다.

•특징: Chart.js 같은 라이브러리를 써서 데이터를 그래프로 보여준다. 사용자가 코드의 보안 상태를 한눈에 파악하고 빠른 결정을 내릴 수 있게 돕는다.

3. VulnerabilityDetail 컴포넌트

•기능: 특정 취약점을 눌렀을 때 자세한 내용을 보여주는 컴포넌트이다. 취약점 종류, 심각도, 코드 위치, AI가 만든 쉬운 설명과 수정 코드 예시를 보여준다. 수정 코드는 '복사' 버튼을 같이 뒤서 사용자가 바로 가져다 쓸 수 있게 한다.

•특징: 코드 부분은 하이라이팅해서 가독성을 높이고, AI 설명은 마크다운으로 깔끔하게 보여준다. 사용자가 AI 가이드를 직접 보고 바로 적용할 수 있는 핵심 화면이다.

4. AnalysisHistory 컴포넌트

•기능: 사용자가 예전에 분석했던 기록들을 목록으로 보여준다. 각 기록을 누르면 옛날 분석 결과를 다시 볼 수 있다.

•특징: 페이지징이나 무한 스크롤 기능을 넣어서 분석 기록이 많아져도 편하게 볼 수 있게 만든다. 사용자가 자기 분석 기록을 관리하는 데 도움을 준다.

다. 프로젝트 수행 방법

- 해당 과제 수행 일정(어떻게 어떤 일정으로 서비스를 만들어 갈 것인지 설명)

SecureLens 프로젝트는 애자일 방법론에 따라 8주 동안 진행한다. 매주 명확한 목표를 세우고, 공부와 개발을 같이 하면서 점진적으로 기능을 완성해 나갈 것이다.

•주차별 스프린트: 8주를 8개의 스프린트로 나눠서 매주 해야 할 공부와 개발 목표를 정한다. 이걸로 프로젝트 진행 상황을 관리하고, 필요할 때 계획을 유연하게 바꿀 수 있다.

•학습과 개발 병행: 새로운 기술(FastAPI, React, OpenAI API 등)을 먼저 공부하고, 바로 실제 코드에 적용하는 방식으로 진행한다. 이렇게 하면 공부한 걸 바로 써먹으면서 실력을 키울 수 있다.

•MVP 중심 개발: 처음부터 모든 기능을 완벽하게 만들기보다, 가장 핵심적인 기능(코드 분석, AI 설명, 대시보드)이 돌아가는 최소 버전(MVP)을 2달 안에 만드는 데 집중한다. 그 후에 시간이 남으면 추가 기능을 붙여나가는 방식으로 진행한다.

•꾸준한 기록과 포트폴리오 활용: 개발하면서 겪은 문제, 해결 방법, 배운 점들을 꾸준히 기록해서 나중에 포트폴리오 자료로 쓴다. GitHub README나 기술 블로그에 정리하고, 프로젝트 시연 영상도 만들어서 프로젝트의 가치를 잘 보여줄 것이다.

•Git & GitHub 활용: 매일 코드를 커밋하고, 기능별로 브랜치를 나눠서 코드 변경 기록을 체계적으로 관리한다. 이걸 협업 연습도 되고, 코드 안정성을 지키는 데도 중요

하다.

라. 개발일정

일련 번호	세부 개발내용	세부 추진 일정 (주)										비 고
		1	2	3	4	5	6	7	8	9	10	
1	주요 UI 구현											
2	세부 UI 구현											
3	주요 기능 구현											
4	세부 기능 구현											
5	요구 사항 분석											
6	프로젝트 테스트 및 오류 수정											
7	프로젝트 마무리 및 보고서 작성											
8												